



CERTIFICATION QUICK RECALL

Data Protection Officer Flashcards

Condensed question-and-answer cards for rapid revision of definitions, principles, rights, forms, deadlines and penalties.

Document Flashcards

Standard Cyber & Data Protection Act [Chapter 12:07] · SI 155 of 2024

Prepared with VAKA OS

Cover the **A:** line and answer aloud. Cite the instrument where noted. (Act = Cyber and Data Protection Act [Chapter 12:07]; SI = SI 155 of 2024.)

Foundations

Q: What is the primary data protection statute in Zimbabwe? **A:** The Cyber and Data Protection Act [Chapter 12:07] (Act 5 of 2021).

Q: Who is the Data Protection Authority? **A:** POTRAZ — Postal and Telecommunications Regulatory Authority of Zimbabwe.

Q: What does SI 155 of 2024 regulate? **A:** Licensing of data controllers and appointment of data protection officers.

Q: Under what section were the DPO guidelines issued? **A:** Section 20(6) of the Act.

Definitions

Q: Data controller? **A:** A person who, alone or jointly, determines the *purposes and means* of processing personal data.

Q: Data processor? **A:** A person who processes personal data on behalf of the controller.

Q: Data subject? **A:** The identified/identifiable natural person the data relates to.

Q: Biometric data (SI definition + examples)? **A:** Physiological characteristics related to a data subject — fingerprints, palm veins, face recognition.

Q: Sensitive/special personal data? **A:** Racial/ethnic origin, political opinions, religious/philosophical beliefs, trade-union membership, health, sex life, biometric/genetic data, criminal history.

The principles

Q: List the seven principles. **A:** Lawfulness/fairness/transparency; purpose limitation; minimisation; accuracy; storage limitation; integrity & confidentiality (security); accountability.

Q: Which principle is breached by keeping data far longer than needed? **A:** Storage limitation.

Q: Which principle makes the controller responsible for demonstrating compliance? **A:** Accountability.

Lawful bases & rights

Q: Name the six lawful bases. **A:** Consent; contract; legal obligation; vital interests; public interest; legitimate interests.

Q: List the data subject rights. **A:** Be informed; access; rectification; erasure; object; restrict; not be subject to solely automated decisions; complain to POTRAZ.

Q: Can a solely-automated decision with legal effects be made? **A:** Only with the data subject's consent or where a law provides for it (SI s.10(3)).

Licensing (SI ss.3-9)

Q: Which form applies for a data controller licence? **A:** Form DP1.

Q: The four tiers by number of data subjects? **A:** Tier 1: 50–1,000 · Tier 2: 1,001–100,000 · Tier 3: 100,001–500,000 · Tier 4: >500,000.

Q: Initial/renewal fees by tier? **A:** T1 USD 50 · T2 USD 300 · T3 USD 500 · T4 USD 2,500 (application fee USD 30 for T2/3/4).

Q: How long is a licence valid, and when do you renew? **A:** 12 months; renew at least 3 months before expiry.

Q: POTRAZ's decision window on an application? **A:** 14 days.

Q: Three licensing exemptions? **A:** Personal/family/household affairs; law enforcement; journalistic/historical/archival. (Last two must still register.)

The DPO (SI ss.12-14)

Q: Which form notifies POTRAZ of a DPO appointment? **A:** Form DP2.

Q: Deadline to appoint a DPO? **A:** Within 90 days of promulgation or of the previous DPO's contract ending.

Q: Deadline to notify POTRAZ of a change/departure of DPO? **A:** 14 days.

Q: DPO qualification routes (SI s.13)? **A:** Data science; data analytics; information security systems; information systems audit; law; audit; or other relevant qualification — plus knowledge of data protection law and the controller's business.

Q: The six DPO functions (SI s.14)? **A:** (a) Monitor compliance (audits, training, awareness); (b) handle POTRAZ & data-subject requests; (c) advise employees; (d) advise on/monitor DPIAs; (e) liaise with POTRAZ; (f) act as data-subject contact point.

Q: How often must a DPO recertify? **A:** Annually — the controller must provide CPD training (SI s.10(1)).

Q: Who stays accountable for the DPO's and processors' acts? **A:** The data controller (SI s.10(4)).

Security & breaches (SI ss.16-17)

Q: Report a breach to POTRAZ within...? **A:** 24 hours, on Form DP3.

Q: Notify affected data subjects of a high-risk breach within...? **A:** 72 hours.

Q: Respond to a POTRAZ breach info request within...? **A:** 14 days.

Q: Conclude the breach investigation and submit report within...? **A:** 21 days of notification.

Q: What four security qualities must measures ensure? **A:** Security, confidentiality, integrity and availability.

Q: What must controllers notify POTRAZ about (s.10(2))? **A:** All processing activities; modifications to indirectly-collected data; cross-border transfers; biometric/genetic data processing.

Penalties

Q: Standard penalty for most contraventions? **A:** Fine up to level 11 and/or up to 7 years imprisonment.

Q: Penalty for failing to appoint a DPO? **A:** Level 7 and/or up to 2 years — the notable exception (lower).

Q: Penalty for training without POTRAZ accreditation? **A:** Level 11 and/or up to 7 years.

Forms cheat-sheet

Q: DP1 / DP2 / DP3? **A:** DP1 = controller licence application/renewal · DP2 = DPO appointment notification · DP3 = breach notification.

The one-minute number drill

24h breach→POTRAZ · 72h→data subjects · 14d POTRAZ decision / DPO change / info request · 21d breach report · 90d appoint DPO · 3mo renewal lead · 6mo transition · 12mo licence · annual recert · USD 1,250/1,450 training · USD 30/50 application.